

Countering GATTACA: Efficient and Secure Testing of Fully-Sequenced Human Genomes

Summary

The paper addresses privacy challenges arising from the imminent availability of low cost fully sequenced human genomes. It focuses on three applications: paternity tests, personalized medicine, and genetic compatibility tests. Instead of generic secure computation, the authors leverage domain knowledge to design efficient protocols based on private set intersection (PSI), PSI cardinality (PSI CA), and authorized PSI (APSI). For paternity testing, they emulate RFLP analysis using fragment lengths rather than full genome comparison, reducing online time to milliseconds. For personalized medicine, they use APSI to let a pharmaceutical company check a patient's genome against an FDA authorized fingerprint without revealing the fingerprint. For genetic compatibility, they use PSI to test if a partner carries a disease mutation. Experiments on commodity hardware show the protocols are practical, with offline preprocessing and very fast online phases.

Strengths

- Leverages biological domain knowledge to avoid generic expensive computation
- Achieves millisecond online times for paternity and personalized medicine tests
- Provides formal security arguments and uses well studied cryptographic building blocks

Weaknesses

- Relies on semi honest adversary model; malicious security only mentioned as future extension
- Requires trusted setup for the authorization authority in personalized medicine
- Does not address malicious clients who might inflate inputs to harvest genomic data

Comments On Strengths & Weaknesses

First, the paper's key strength is its use of biological domain knowledge to drastically reduce computational overhead. Instead of comparing entire three billion nucleotide genomes, the paternity test protocol mimics real world RFLP analysis by digesting genomes with restriction enzymes and comparing only fragment lengths for a small set of markers. This reduces online work from days (as in the strawman approach) to just a few milliseconds. Similarly, personalized medicine and genetic compatibility tests limit comparisons to small fingerprints of mutations rather than scanning the whole genome. This design choice makes privacy preserving genomic computation practical on today's hardware, even on smartphones. Second, the authors build on well established cryptographic primitives like PSI, PSI CA, and APSI, which have been proven secure under standard assumptions. This allows them to inherit security proofs and focus on efficiency optimizations such as precomputing offline work on the server side once per genome. However, the paper has clear limitations. It assumes semi honest participants who follow the

protocol but may try to learn extra information. The authors mention that extensions to malicious security exist for the building blocks but do not implement or evaluate them. In real world genomic testing, a malicious party could deviate from the protocol to steal genetic data, for example a client could inflate its fingerprint input to probe the server's genome for many positions beyond the intended test. The paper acknowledges this open problem but does not solve it. Another weakness is the trusted setup required for personalized medicine. The FDA or similar authority must generate RSA keys and issue authorizations. If this authority is compromised, the entire privacy guarantee fails. Moreover, the protocol does not prevent a pharmaceutical company from running many tests on the same patient's genome using different authorized fingerprints, potentially learning more than intended. Despite these concerns, the work represents an important step toward practical privacy preserving genomic testing by showing that careful protocol design can achieve efficiency without sacrificing security.